

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

System and Communications Protection Procedures for Encryption Mechanisms (SC- 12, 13, and 17)

System and Communications Protection Procedures for Encryption Mechanisms (SC-12, 13, and 17)

Table of Contents

1.0. Document Purpose 3

2.0. Scope 3

3.0. Procedure Conflict 3

4.0. Roles and Responsibilities 3

5.0. Management Commitment 3

6.0. Coordination Among Agency Entities 3

7.0. Compliance 3

8.0. Procedures 4

9.0. Document Details 7

10.0. Review 7

11.0. Records Management 7

12.0. Public Records Exceptions 7

13.0. Definitions 8

14.0. Abbreviations 9

System and Communications Protection Procedures for Encryption Mechanisms (SC-12, 13, and 17)

1.0. Document Purpose

The purpose of this document is to define the State of Maine procedures for implementing secure encryption mechanisms for State of Maine information assets (see Definitions). This part of the security program is focused on protecting the confidentiality (see Definitions), integrity (see Definitions), and availability (see Definitions) of State information assets. This document corresponds to the System and Communications Protection Procedures for Encryption Mechanisms (SC- 12, 13, and 17) Control Family of National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).[1].

2.0. Scope

2.1. These procedures apply to State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Procedure Conflict

If these procedures conflict with any law or union contract in effect, the terms of the existing law or contract prevail.

4.0. Roles and Responsibilities

Please refer to the System and Communications Protection Policy and Procedures (SC)[2] document for further information.

5.0. Management Commitment

The State of Maine is committed to following these procedures and the policy that it supports.

6.0. Coordination Among Agency Entities

Please refer to the System and Communications Protection Policy and Procedures (SC)[3] document for further information.

7.0. Compliance

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

---

1 https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemCommunicationsProtectionPolicy.pdf
[3] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemCommunicationsProtectionPolicy.pdf

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of Maine data and systems. Employers of contractors will be notified of any violations.

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following standards apply to and represent the security controls established to meet an acceptable level of protection for the State of Maine's information assets supported by the encryption mechanisms addressed in this document.

8.1. SC Controls Cross References:

8.1.1. The following controls for the System and Communications Protection Policy and Procedures (SC) are published in separate policy and procedure documents:

8.1.1.1. System and Communications Protection Policy and Procedures (SC)[4];

8.1.1.2. System and Communications Protection Procedures for Defense in Depth (SC-2, 4, 5, 20, 21, 22, 23, 28, 32, 39)[5];

8.1.1.3. System and Communications Protection Procedures for Specific Technologies (SC-10, 15, 18, 40)[6]; and

8.1.1.4. System and Communications Protection controls applicable exclusively to Federal Tax Information (FTI), including Voice over Internet Protocol (SC-19), are addressed in IRS Publication 1075–scoped documentation and are not implemented within the general System and Communications Protection procedures.

8.2. Cryptographic Key Establishment and Management (SC-12)

8.2.1. The Office of Information Technology (OIT) Computing Infrastructure and Services and OIT Enterprise Data Services use Entrust Certificate Authority (CA) (see Definitions) for external-facing applications (see Definitions). Entrust, or OIT public key infrastructure (PKI) (see Definitions), certificates are used for internal-facing applications. OIT cryptographic key management is established in the Identification and

[4] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemCommunicationsProtectionPolicy.pdf
[5] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCDefenseInDepthProcedures.pdf
[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCSpecificTechnologies.pdf

Authorization (IA) policy, 8.4.8[7] (Intranet only) and is Federal Information Processing Standards (FIPS) 140-2 compliant or stronger.

8.2.1.1. OIT Computing Infrastructure and Services and OIT Enterprise Data Services maintain strict access control that uses the principle of least privilege (see Definitions) for administrators. This ensures the availability of cryptographic keys in the event of key loss, such as forgotten passphrases.

8.2.1.2. OIT Information Asset Owners use product-specific features and internal administrative monitoring to guard against modification, substitution, and destruction of cryptographic keys. Private keys (see Definitions) are also protected against unauthorized disclosure.

8.2.1.3. Encryption key storage is managed by each Asset Owner through either dedicated hardware or software modules.

8.2.1.3.1. Backups and recoveries are handled by Computing Infrastructure and Services and/or Enterprise Data Services. Backups are performed nightly, and daily reports of any failures are immediately addressed.

8.2.1.3.2. Access to Encryption Keys is limited only to authorized personnel.

8.2.1.3.3. Encryption keys are properly stored, separately from data.

8.2.1.4. In general, exportation of the PKI private key is prohibited. See 8.4.6.1 of Configuration Management Policy[8] for permitted use cases.

8.2.2. **Cryptographic Key Establishment and Management, Symmetric Keys:** OIT Computing Infrastructure and Services produces, controls, and distributes symmetric cryptographic keys using Microsoft Windows server root CA[9] and the public certificate authority, Entrust, for encryption and decryption. These dedicated hardware and software modules are approved by the National Security Agency (NSA), a government organization, and are FIPS-compliant.

8.3. **Cryptographic Protection (SC-13)**

---

[7] https://inet.state.me.us/oit/policies/documents/IdentificationAuthenticationPolicy.pdf
[8] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ConfigurationManagementPolicy.pdf
[9] https://docs.microsoft.com/en-us/windows-server/networking/core-network-guide/cncg/server-certs/server-certificate-deployment-overview

8.3.1. OIT Client Technologies enforces the protection of information systems and data storage as outlined in the Identification and Authorization (IA) policy, 8.4.8,[10] (Intranet only) in accordance with NIST Special Publication 800-53 and is FIPS 140-2 compliant.

8.3.2. Sensitive and restricted data: OIT uses external or removable storage devices that are encrypted to the AES-256 standard.

8.3.3. OIT has adopted the Federal Homeland Security Traffic Light Protocol (TLP)[11] (see Definitions) as the taxonomy of organizing data into categories so that data may be used and protected efficiently, and to determine the appropriate level of risk management needed for unencrypted transmission (see Definitions) to a party not served by the OIT internal network (see the Data Exchange Policy). [12]

8.3.4. Laptop storage devices: OIT uses Trellix (formerly McAfee) encryption for internal/fixed storage devices.

8.3.4.1. External or removable storage devices are encrypted upon agency/department request. These external storage devices include State of Maine-issued and State of Maine-owned media devices, such as Secure Digital (SD) Cards, Digital Video Disks (DVDs), Media Players (MPs) (see Definitions), and Flash Drives, which are used to conduct State of Maine business.

8.3.4.2. Lookout (see Definitions) and Microsoft Intune (see Definitions) encrypt all State of Maine Android phones/tablets and iPhone/iPad mobile phones/tablets. See the Media Protection Policy (MP-1)[13] (Intranet only).

8.4. Public Key Infrastructure Certificates (SC-17)

8.4.1. OIT Computing Infrastructure and Services uses a NIST-approved secure process for PKI CAs. This secured process ensures that only approved trust anchors (see Definitions) are used for its information system trust stores (see Definitions), including certificates with visibility external to organizational systems and certificates supporting internal system operations, as outlined in the Identification and Authorization (IA) policy, 8.4.8[14] (Intranet only).

[10] https://inet.state.me.us/oit/policies/documents/IdentificationAuthenticationPolicy.pdf
[11] https://www.cisa.gov/tlp
[12] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/DataExchangePolicy.pdf
[13] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/AccessControlProceduresForUsers.pdf
[14] https://inet.state.me.us/oit/policies/documents/IdentificationAuthenticationPolicy.pdf

8.4.2. Registration of PKI certificates is strictly controlled by administrators in OIT Computing Infrastructure and Services using the principle of least privilege.

8.4.3. Authenticity of Entrust-issued PKI certificates: Entrust validates the authenticity of the State of Maine's ownership of PKI certificates being issued during the time of issuance.

8.4.4. In general, exportation of the PKI private key is prohibited. See 8.4.6.1 of Configuration Management Policy[15] for permitted use cases.

9.0. Document Details

9.1. Initial Issue Date: April 28, 2023

9.2. Latest Revision Date: Dec 08, 2025

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[16]

9.6. Waiver Process: Waiver Policy[17]

9.7. Distribution: Internet[18]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after withdrawal or replacement and then destroyed in accordance with guidance[19] provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[20] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the

[15] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ConfigurationManagementPolicy.pdf
[16] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[17] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[18] https://www.maine.gov/oit/policies-standards
[19] https://www.maine.gov/sos/sites/maine.gov.sos/files/content/assets/GS1Administrative.pdf
[20] https://legislature.maine.gov/statutes/1/title1sec402.html

Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

13.0. Definitions

13.1. Asymmetric Key Cryptography: A cryptographic system where users have a private key that is kept secret and used to generate a public key (which is freely provided to others). Users can digitally sign data with their private key, and the resulting signature can be verified by anyone using the corresponding public key. Also known as public-key cryptography. Source: NIST.[21]

13.2. Certificate Authority: A trusted entity that issues and revokes public key certificates. Source: NIST.[22]

13.3. External Facing Applications: Applications that are open to the internet and provide content to public users, internal employees, and business partners.

13.4. Lookout: A data protection and cloud security platform.

13.5. Media Player (MP): Software that "plays" audio, video, or animation files on a computer. Windows Media Player is the default player from Microsoft, but iTunes, RealPlayer, and other software are also widely used. iTunes and QuickTime Player are the default products for Mac devices.

13.6. Microsoft Intune: A cloud-based service that focuses on mobile device management and mobile application management for mobile phones, tablets, and laptops (part of Microsoft Endpoint Manager).

13.7. Principle of Least Privilege: A security principle where users are assigned the minimal access necessary to perform their job responsibilities. Access is granted for the shortest duration possible.

13.8. Private Key: A cryptographic key, used with a public key cryptographic algorithm, that is uniquely associated with an entity and is not made public. Source: NIST.[23]

13.9. Public Key Infrastructure (PKI): The architecture, organization, techniques, practices, and procedures that collectively support the implementation and operation of a certificate-based public key cryptographic system. Framework established to issue, maintain, and revoke public key certificates. Source: NIST.[24]

13.10. Traffic Light Protocol (TLP): The Federal Homeland Security Traffic Light Protocol is used by OIT for the classification of Personally Identifiable Information (PII) impact level. See the Data Classification Policy.[25]

---

[21] https://csrc.nist.gov/glossary/term/asymmetric_key_cryptography
[22] https://csrc.nist.gov/glossary/term/certificate_authority
[23] https://csrc.nist.gov/glossary/term/private_key
[24] https://csrc.nist.gov/glossary/term/pki
[25] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/DataClassificationPolicy.pdf

13.11. Trust Anchor: The end-entity certificate used to validate the identity of an entity such as a website, business, or person.

13.12. Trust Store: A list of root, intermediate, and user certificates that are trusted by the operating system or application.

13.13. Unencrypted Transmission: A communication method that does not meet encryption requirements as outlined in the Transmission of Sensitive Information Standard. For example, confidential or sensitive data may be intercepted by a malicious user by monitoring plaintext data that is transmitted across an unencrypted network to gain unauthorized access. This method can jeopardize the confidentiality of sensitive data.

14.0. Abbreviations

14.1.	AES:	Advanced Encryption Standard
14.2.	CA:	Certificate Authority
14.3.	DVD:	Digital Video Disks
14.4.	FIPS:	Federal Information Processing Standards
14.5.	FOAA:	Freedom of Access Act (Maine)
14.6.	MP:	Media Players (MP3 and MP4)
14.7.	NIST:	National Institute of Standards and Technology
14.8.	NSA:	National Security Agency
14.9.	OIT:	Office of Information Technology
14.10.	PII:	Personally Identifiable Information
14.11.	PKI:	Public Key Infrastructure
14.12.	SC:	System and Communications Protection Policy and Procedures
14.13.	SD:	Secured Digital Cards
14.14.	SOM:	State of Maine
14.15.	TLP:	Traffic Light Protocol